Stored XSS in Conversations (Messenger) module

Severity

CVSS:4.0/AV:N/AC:L/AT:P/PR:L/UI:P/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

Environment

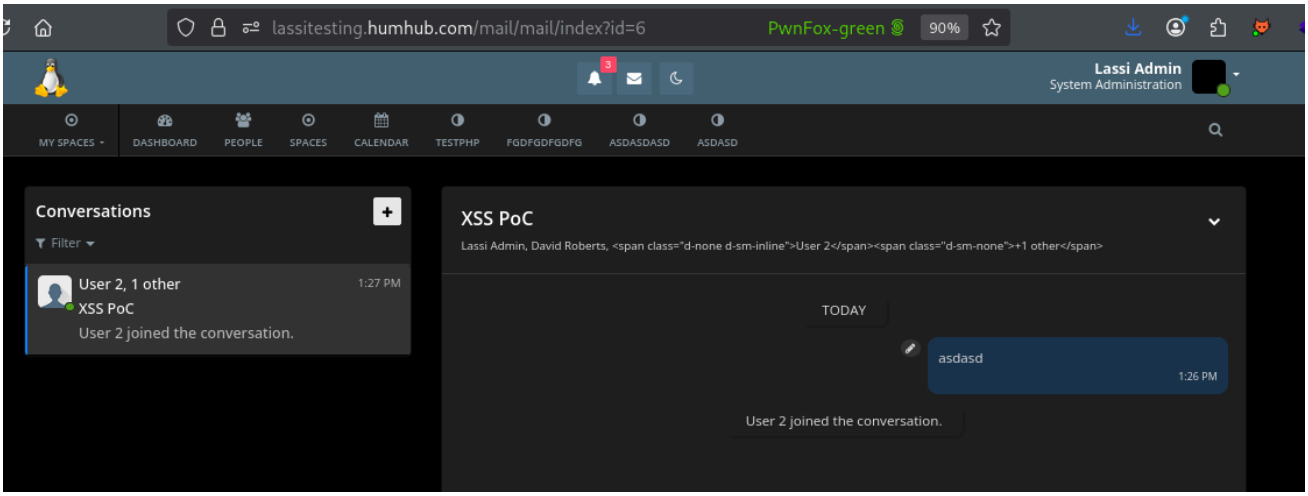
HumHub Professional Edition Demo version `1.18.1`, at https://lassitesting.humhub.com

Messenger module version `3.3.8` (https://github.com/humhub/mail)

Created at https://saas.humhub.com/en/create on 23.2.2026, updated to `1.18.1` on 3.3.2026 by the lovely HumHub team.

Steps to reproduce

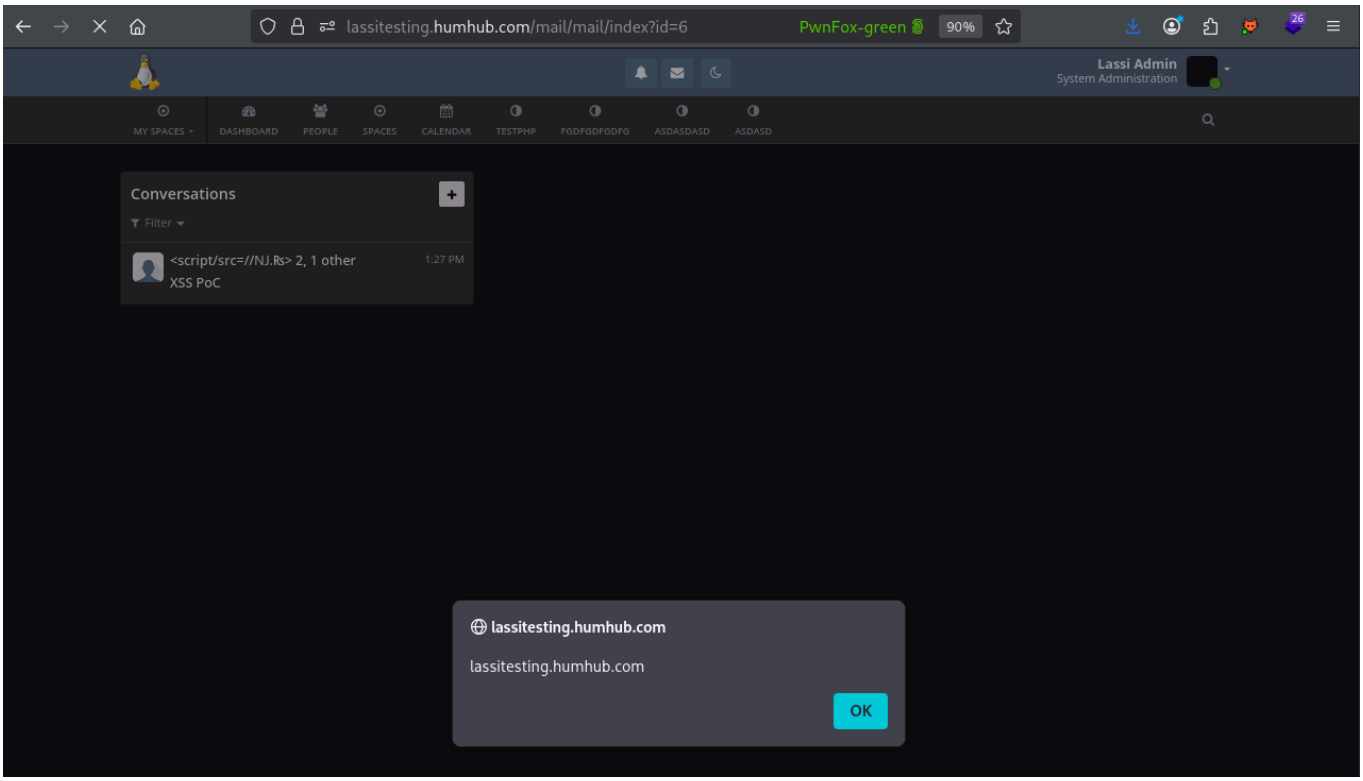
1. Log in to your **HumHub** instance with any user. In this example, the default `admin` account was used
2. From the top menu, go to **Conversations** and create a new conversation with any values
3. From the arrow menu in the conversation, click **Add user** and add some user. In this example, `user2` was added



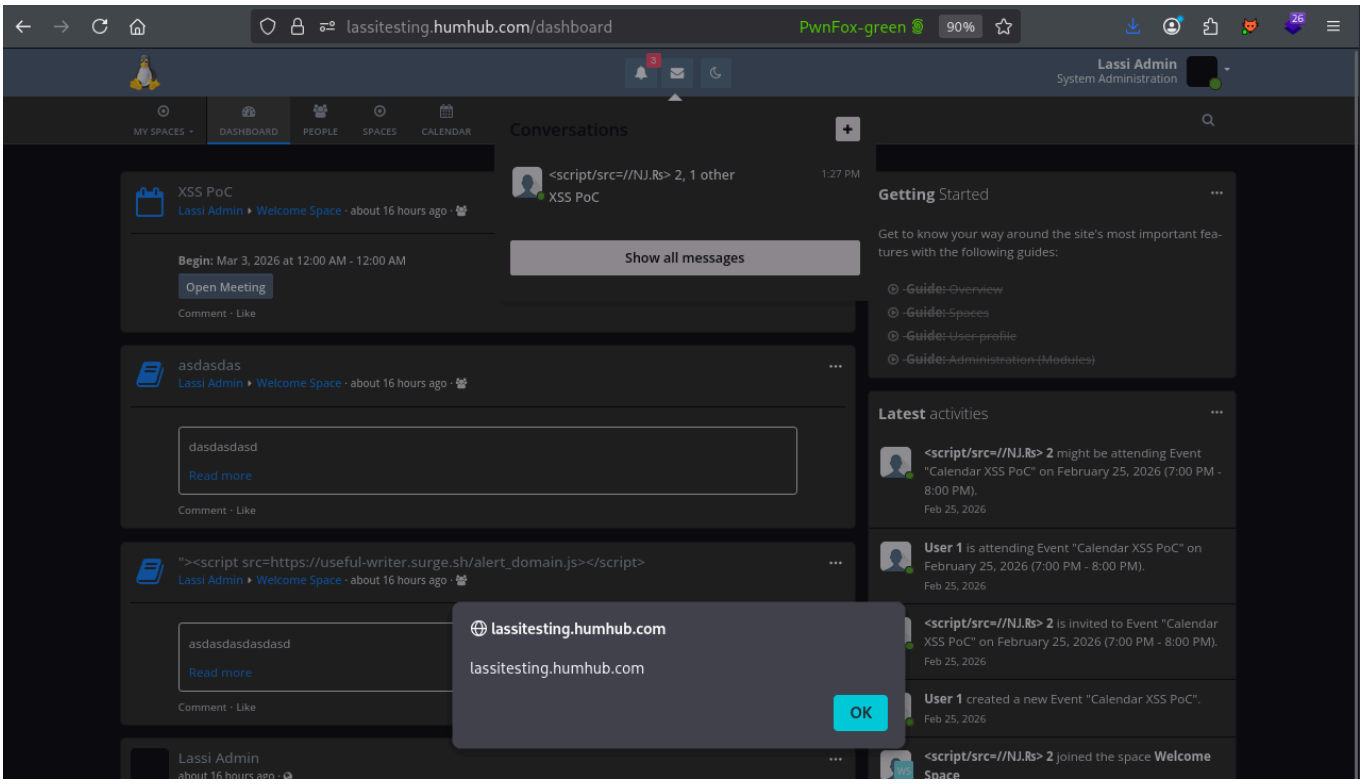
4. In another browser session, log in with the user from the previous step
5. Navigate to **Settings > Profile > General**
6. Enter the following XSS payload to the **First name** field and click **Save profile**:

```
<script/src=//NJ.Rs>
```

(payload courtery of @terjanq. First name only accepts input <= 20 characters.)
7. Back on the user from step 1, refresh the **Conversations** view. XSS fires immediately:



8. XSS also fires from the **Conversations** widget in the top menu:



Code References

`{username}` is not HTML encoded in the "joined the conversation" message.

https://github.com/humhub/mail/blob/de2026aedd0963216b8bdb7785744dc6be807069/models/MessageNotification.php#L193

https://github.com/humhub/mail/blob/de2026aedd0963216b8bdb7785744dc6be807069/widgets/ConversationStateBadge.php#L51

Note in the above, "{username} left the conversation" is not HTML encoded either, which might be an easier attack path. XSS works also here.

External references

https://cwe.mitre.org/data/definitions/79.html
https://owasp.org/www-community/attacks/xss/
https://portswigger.net/web-security/cross-site-scripting